Udyam Express — data privacy & security note

Airtel SYNC 2026 · Track A · designed to the Digital Personal Data Protection Act, 2023 (DPDP) · all prototype data is synthetic

1. Consent before collection (DPDP s.5–6)

Before any document is uploaded the owner sees a plain-language notice in their language listing **each purpose separately**: KYC verification (required by telecom rules), registry look-up, order contact, and marketing (optional, off by default). The API refuses uploads without a KYC consent record (HTTP 403). Each consent is stored with notice version and timestamp in an **append-only, SHA-256 hash-chained ledger** so it can't be edited silently. **Withdraw & erase** is one tap and deletes the KYC result.

2. Purpose limitation & data minimisation

Step	We collect	We deliberately don't
Advisor chat	Business type, city, staff, sites, needs, optional GSTIN/Udyam	Aadhaar, PAN, bank, email or phone in chat — redacted before storage and before any AI call
Registry look-up	Status + trade name only	Full registry record is not returned to the browser
KYC	4 documents needed for telecom KYC; fields extracted	Aadhaar number (signatory ID uses its own ID no., masked); no photo storage after verdict
Order	Contact name, phone (masked in UI: ••••••3210)	Date of birth, family details
Lead scoring	Business attributes known at lead time	Preferred language excluded so no owner ranks lower for the language they speak

3. Where data goes

- **Documents never leave Accel's servers**: OCR runs on our own server (Tesseract + OpenCV), in memory; images are not sent to any AI model.
- The optional language model (Gemini) receives only **redacted chat text**; it cannot set prices or eligibility — any number in its output not present in our own text is discarded.
- Identifiers are **masked in UI, API responses and logs** (GSTIN ••••••••••8P1ZT, Udyam, ID numbers, phone).
- KYC replies never echo registry values back, so a forged document can't be "corrected" by reading our response.

4. Retention

Raw document images: deleted **immediately after the verdict** in the prototype; in production kept encrypted (AES-256, KMS-managed keys) for at most **30 days** for dispute handling, then purged automatically. Extracted KYC fields: retained for the life of the contract + the period telecom KYC rules require, then deleted. Chat transcripts of unclosed leads: 90 days, then anonymised for analytics.

5. Security controls (production path)

- TLS 1.2+ everywhere; files limited to 8 MB images; uploads virus-scanned; server-side re-pricing so the browser can't change a price.
- Role-based access: partners see only leads assigned to them, with masked contact details; every reveal is logged.
- Back office behind SSO + MFA; audit log of KYC decisions; manual-review queue for suspected tampering.
- Data residency in India; breach notification to the Data Protection Board and affected owners as DPDP requires.

6. Data principal rights

Owners can view what we hold, correct it, withdraw consent and request erasure from the app; a named grievance officer (privacy@accel.example) responds within the statutory timeline.

Design principle: collect the least needed for each step, keep it on our own infrastructure, mask it everywhere, and delete it on a schedule. The AI helps the owner talk; it never sees their documents.